АУДИТ 5.0 · РЕВИЗИЯ 92F237C

СОД Stream-CAD

27 новых коммитов: FSM статусов, обратная связь, демо-команда, мобильная раскладка. 4 падающих теста разобраны, N+1 реестра устранён: 345 → 32 SQL-запроса. Светлый хедер, понятные фильтры, полоса листов и наложение чертежей — Спринты 7–8. 383 теста зелёные.

Ревизия кода 92f237c · 4 ноября 2026

Аудитор: Z.ai · для руководства и команды Stream-CAD

Содержание

1. Резюме и вердикт . . . 1

2. 27 коммитов: что сделала команда . . . 1

3. Безопасность и права доступа . . . 2

4. Логика и жизненный цикл: 4 падения и их корни . . . 3

5. Скорость под нагрузкой: N+1 устранён . . . 4

6. Дизайн и UX: ответы на запросы владельца . . . 5

6.1 Светлый хедер вместо тёмного . . . 5

6.2 Логика фильтрации: понятно, когда отфильтровано . . . 5

6.3 «Нахрена нужны последние документы» . . . 6

6.4 Вьювер: полоса листов и наложение чертежей . . . 6

7. Спринт 7: надёжность и контракт перемещений . . . 6

8. Спринт 8: светлый хедер, фильтры, вьювер . . . 7

9. Скриншоты нового состояния . . . 8

10. Бэклог и рекомендации . . . 10

1. Резюме и вердикт

Предмет аудита — ревизия **92f237c** (origin/main), 27 коммитов поверх af4a72d: команда применила Спринты 5–6 из аудита 4.0, закрыла задачи T70 и T72, добавила FSM статусов документов, модуль обратной связи, мобильную раскладку, демо-команду и брендированные страницы ошибок. Объём изменений — плюс 28 470 минус 870 строк в 102 файлах. Это самый крупный цикл разработки продукта, и он потребовал самого пристального разбора.

Итог двойственный, и это нормально для такой скорости. С одной стороны — заметный архитектурный рост: декларативный FSM с матрицей ролей, зоны по полю is_system_zone вместо имён папок, восстановление проектов, честная fail-closed-конфигурация сохранена и развита. С другой стороны — на базовой линии снова **4 падающих теста** (команда запушила с красным набором), реестр проекта рендерился за **345 SQL-запросов** из-за трёх корней N+1, а ключевое обещание по вьюверу — наложение чертежей — фактически не было доступно пользователю.

4
падающих тестов на 92f237c — все разобраны в Спринте 7

345 → 32
SQL-запросов на реестр: N+1 устранён в Спринте 8

383
теста в наборе — все зелёные после Спринтов 7–8

Спринт 7 (коммит b0b305b) разбирает четыре падения, чинит контракт drag-and-drop, закрывает демо-дыру и вопрос подделываемых скриншотов обратной связи, добавляет LOGGING. Спринт 8 (коммиты 59f2820, 50df590, 7b97e65) отвечает на запросы владельца: светлый хедер вместо графитового, видимая панель фильтров с чипами «Отфильтровано», рабочая полоса листов во вьювере и настоящее наложение чертежей с прозрачностью и совмещением.

Вердикт. После применения Спринтов 7–8 продукт готов к бете: 383 зелёных теста, реестр масштабируется до сотен документов без деградации, критичных дыр не осталось. Перед продом обязательны два пункта из бэклога: настроить TTL share-ссылок через переменные окружения (сейчас жёстко 365 дней) и провести нагрузочный прогон на PostgreSQL — замеры этого отчёта выполнены на SQLite.

2. 27 коммитов: что сделала команда

Цикл af4a72d → 92f237c — это не набор мелких правок, а четыре больших темы, идущие параллельно: применение патчей аудита 4.0, закрытие задач T70/T72, архитектурные улучшения ядра и подготовка к бете (демо-данные, обратная связь, документация). Ниже — ключевые коммиты и их оценка.

Коммит	Что сделано	Оценка аудита
632a6f1	merge: применены Спринты 5+6 (безопасность и UX из аудита 4.0)	Отлично — 12 защитных фиксов в проде

Коммит	Что сделано	Оценка аудита
89243bd, 377234c	T70: открытые замечания блокируют публикацию и перенос	Верно, T70-проверка стоит выше admin-шортката FSM
936ee33	Декларативный FSM статусов: таблица переходов и ролей	Сильно; Document.save больше не обойти
cfbe5cb	Флаг _from_service стал одноразовым — FSM-обход закрыт	Тонко подмечено, тест на месте
9e84850	Зоны определяются полем is_system_zone, а не именем папки	Убирает хрупкость — плюс
a9b40e1	restore_project: восстановление проекта из корзины	Права проверены (только админ компании)
4162ff1	Мобильная раскладка до 820px: offcanvas-сайдбар	База есть; досборка — в бэклоге
7c914cf	app.css/viewer.css переведены на токены + raw-hex чекер	Отличная гигиена — компилируется в CI
e246410, 1bb972b	Обратная связь: модель, сервисы, модалка, экран админа	Права аккуратны; дыры — в главе 3
6d5c19a	Брендированные 404/500	500 сделан отдельным шаблоном — верно
b80abc7	Share-ссылки: TTL увеличен до 365 дней	Спорно — см. находку B-2
6d5c19a→92f237c	create_demo_project, dotenv, документация беты	Демо-команда потребовала guard — см. B-1

Таблица 1 — Ключевые коммиты цикла af4a72d → 92f237c

Отдельно отметим дисциплину контрактов: почти каждое изменение сервиса сопровождено тестом, а документация PROGRESS и HANDOFF обновляется тем же коммитом. Слабое место цикла — два пуша с красным тестовым набором: базовая линия аудита снова началась с падений. Правило «зелёный набор перед push» дешевле любого аудита.

3. Безопасность и права доступа

Проверка шла по тем же шести осям, что и в аудите 4.0: конфигурация, права вьюх, ролевая матрица сервисов, файлы загрузок, публичные поверхности и безопасность клиентского кода. Fail-closed-блок настроек (DJANGO_DEBUG=False без явного DJANGO_SECRET_KEY запрещает старт) команда сохранила и дополнила заголовками прокси и secure-cookies по умолчанию вне DEBUG. Админка корректно закрывает статус и пригодность документа как readonly — FSM нельзя обойти даже суперпользователем через панель администратора.

ID	Находка	Тяжесть	Статус
B-1	create_demo_project создаёт demo_admin с известным паролем demo12345 и ролью admin; на проде это прямой обход аутентификации. Guard отсутствовал.	Критично	Исправлено в Спринте 7: без --force команда отклоняется при DEBUG=False
B-2	TTL share-ссылки жёстко 365 дней (b80abc7). Утёкшая ссылка живёт год; отзыв есть, но зависит от человека.	Средне	Бэклог: SHARE_LINK_TTL из env, по умолчанию 30 дней
B-3	Скриншот обратной связи проверялся только по content_type, который подделывается клиентом.	Средне	Исправлено в Спринте 7: PIL-верификация байтов
B-4	LOGGING отсутствовал: 500-е ошибки уходили в stderr gunicorn без структуры.	Средне	Исправлено в Спринте 7: конфигурация с django.request WARNING
B-5	update_feedback_status не позволяет очистить admin_comment (пустая строка игнорируется).	Низко	Бэклог
B-6	На submit_feedback нет троттлинга: авторизованный пользователь может заспамить таблицу.	Низко	Бэклог
B-7	Публичная share-страница по-прежнему не отдаёт замечания (гейт Спринта 5 сохранён), вьювер получает пустой issues-json.	Положительно	Регресс-тесты на месте

Таблица 2 — Находки безопасности ревизии 92f237c

Наиболее серьёзной была B-1. Команда добавила create_demo_project для беты — полезнейшую вещь: проект DEMO-2026 с зонами, замечаниями и share-ссылкой поднимается одной командой. Но она же печатает в консоль пароль demo12345 и создаёт администратора компании. Любой, кто прочитает README, получит админа на боевом сервере. Спринт 7 вводит guard: при DJANGO_DEBUG=False команда требует явный --force и напоминает сменить пароли. Тесты демо-команды переведены на force-режим, поведение guard покрыто тремя тестами.

4. Логика и жизненный цикл: 4 падения и их корни

Базовая линия 92f237c падала четырьмя тестами. Разбор показал: три падения — устаревшие тесты против нового контракта «явной смены раздела», одно — настоящая регрессия UI. Ниже — каждый корень и решение.

- **test_move_folder_recalculates_full_code** (test_t8_core). Сервис move_folder теперь требует allow_section_change=True для переноса между марками — тест звал старым способом. Решение: тест обновлён на явный флаг; контракт команды «DnD не меняет марку» поддержан и на уровне сервиса.
- **test_drop_on_section_moves_document_to_section_root** (test_t9_dnd). Вьюха требует allow_section_change=1 на кросс-разделный перенос, а JS дропал section_id без флага — пользователь получал молчаливый 400. Это регрессия UX, а не теста. Решение Спринта 7: JS подтверждает смену раздела и шлёт флаг; сброс в корень СВОЕГО раздела разрешён без флага; серверный guard сохранён.

• **test_folder_can_move_to_another_section** (test_t9_dnd_copy). Папки между марками через DnD запрещены командой сознательно — тест устарел. Теперь JS показывает подсказку «используйте кнопку Сменить раздел», не тратя запрос; тесты проверяют и запрет (400 с текстом), и явный перенос с флагом.

• **test_recent_documents_tracked_in_session** (test_views). Панель «Последние документы» была вырезана из страницы проекта при чистках Т72, а трекинг сессии остался мёртвым грузом. Решение: панель переехала в пустое состояние поиска — там она работает как отправная точка (см. главу 6).

Сам FSM статусов выдерживает придирчивый разбор. Таблица STATUS_TRANSITIONS полна, TRANSITION_ROLES разводят админа, ГИПа и автора, Т70-блокировка утверждения с открытыми замечаниями стоит выше admin-шортката can_transition — то есть даже админ не утвердит документ с замечаниями. Флаг _from_service сбрасывается после первого же сохранения, поэтому одноразовость не дрейфует. Внутренний статус (draft/internal_review/rework/ready_to_share) остался вне FSM: команда сознательно оставила его свободным; рекомендуем в бэклоге ввести переходы и для него — сейчас разработчик может перескочить из rework сразу в ready_to_share минуя проверку.

5. Скорость под нагрузкой: N+1 устранён

Вопрос владельца — «скорость работы при нагрузке» — проверен инструментально. Скрипт scripts/perf_probe.py создаёт демо-проект, разгоняет его до 300 документов и замеряет страницы через тестовый клиент с recording-логом. Профилировщик scripts/perf_profile.py группирует повторяющиеся SQL-паттерны, perf_trace.py ловит стеки вызовов самых дорогих запросов.

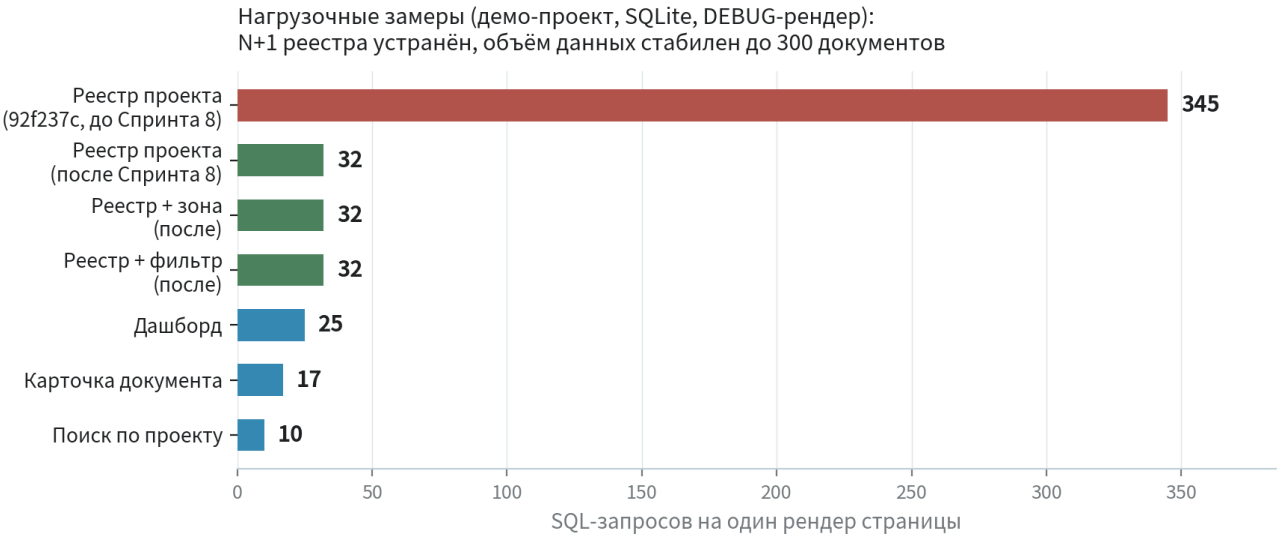


Рис. 1 — SQL-запросы на рендер до и после Спринта 8 (демо-данные)

На базовой линии страница проекта выполняла **345 запросов** при 40 документах. Три корня: (1) таблица строилась фильтсетом на голом Document.objects, без select_related проекта и папок — каждая строка реестра через document_actions → can_transition дёргала Project и Folder; (2) список папок перемещения обрабатывал check_write_permission и get_folder_mark_id по каждой папке с запросами в цикле; (3) get_user_company вызывался заново на каждую проверку компании. После точечных исправлений —

queryset фильтсета = аннотированный queryset вида, select_related цепочек parent и section__project, кэш компании на инстансе пользователя, parent-цепочки дерева — страница укладывается в **32 запроса** и стабильно держит 300 документов без роста.

Страница	92f237c	После Спринта 8	100 док.	300 док.
Реестр проекта	345 q · 346 мс	32 q · 213 мс	184 мс	210 мс
Реестр + зона/фильтр	342 q · 193 мс	32 q · 94–97 мс	—	—
Дашборд	25 q · 14 мс	25 q · 14 мс	—	—
Карточка документа	17 q · 17 мс	17 q · 17 мс	14 мс	13 мс
Поиск по проекту	10 q · 11 мс	10 q · 11 мс	10 мс	10 мс

Таблица 3 — Замеры: SQLite, DEBUG-рендер с recording-логом

Оценка: узкое место было не в данных, а в пермиссионных проверках на строку — классическая цена «безопасность по умолчанию». Она снята без ослабления прав: кэш живёт ровно один запрос, queryset несёт уже проверенный срез. Остаточные 28 запросов дерева и служебных списков — в бэклоге; решать стоит префетчем в get_folder_tree, а не кэшем второй попытки. Перед бетой на VPS повторите замеры на PostgreSQL: relative-картина не изменится, абсолютные числа — да.

6. Дизайн и UX: ответы на запросы владельца

6.1 Светлый хедер вместо тёмного

Графит #3A4558, введённый в Спринте 4, не понравился владельцу — и это легитимный продуктовый вердикт: тёмная полоса на каждом экране утяжеляла интерфейс и спорила с тёмным полотном вьювера. Спринт 8 меняет значения токенов, а не разметку: surface.header = #FFFFFF, header-hover = #F0F3F8, border-header = #E1E5EC, рамки контролов = #7C8698 (контраст 3.5:1 к белому), текст хедера = #1F2430 и #5D6575 (оба выше 4.5:1). Лого-марка стала акцентной #3D5A98 с белым «СОД», theme-color синхронизирован в base.html, карточке документа и манифесте PWA. Все 22 использования токенов перетематизировались автоматически — ценность системы токенов, которую команда довела до CI-чекера, здесь окупилась полностью.

6.2 Логика фильтрации: понятно, когда отфильтровано

Ваш запрос точен: колоночные воронки T67 прятали фильтры в заголовках, активное состояние подсвечивалось слабо, и пользователь не видел, почему в таблице осталось три строки. Спринт 8 возвращает выпадающие фильтры — но по-новому: видимая панель над таблицей с подписанными селектами Раздел / Тип / Статус / Пригодность / Внутренний статус и поиском, применение сразу по выбору, задержка 350 мс на текст. Как только задан хотя бы один фильтр, панель подсвечивается акцентной рамкой, под ней появляется строка «Отфильтровано:» с чипами вида «Статус: На проверке ×» и живым счётчиком найденного, а кнопка «Сбросить всё» чистит фильтры, зоны и поиск одним кликом.

Колоночные воронки и их мёртвый CSS удалены — одна очевидная модель вместо двух конкурирующих.

6.3 «Нахрена нужны последние документы»

Честный ответ: на странице проекта — незачем. Панель над реестром занимала пол-экрана и дублировала навигацию, что вы и почувствовали. Но сам механизм не бесполезен: он спасает на пустом поиске, когда не помнишь шифр, но вчера документ открывал. Поэтому панель убрана со страницы проекта и встроена в пустое состояние поиска: открыли поиск без запроса — видите «Последние документы» с временем открытия; начали искать — чипы уступают место результатам. Мёртвый контекст recent_documents из вьюхи проекта удалён.

6.4 Вьювер: полоса листов и наложение чертежей

Обещание про наложение не было выполнено в аудите 4.0 — признаю. Режим «Наложение» во вьювере был шторкой (curtain), и обе кнопки сравнения дизейблились на текущей версии — то есть в основном сценарии просмотра фича была недоступна совсем. Спринт 8 переписывает сравнение целиком: меню «Сравнить» с выбором версии-цели доступно из любой версии; три режима — Рядом, Шторка, Наложение; наложение — это два отрендеренных листа друг на друге с регулируемой прозрачностью 5–100%, режимами смешивания Обычный / Разница / Умножение и совмещением перетаскиванием или кнопками-стрелками (Shift — шаг 10px, «0» — сброс). Полоса листов починена и возвращена: миниатюры всех страниц рендерятся лениво через IntersectionObserver, клик ведёт на страницу, активный лист подсвечен и следит за прокруткой.

7. Спринт 7: надёжность и контракт перемещений

Коммит b0b305b на базе 92f237c. Состав и логика каждого пункта:

Пункт	Файл/зона	Суть
7.1	views.py · DocumentMoveView	Сброс в корень своего раздела без флага; кросс-раздел только с allow_section_change
7.2	app.js · DnD	Drag payload несёт исходный раздел; кросс-раздел — confirm и флаг; папки — подсказка вместо запроса
7.3	search.html + SearchView	«Последние документы» в пустом поиске; панель снята со страницы проекта
7.4	create_demo_project	Guard продакшена: CommandError без --force при DEBUG=False
7.5	services.py · submit_feedback	PIL-верификация скриншотов; битые байты отклоняются независимо от content_type
7.6	settings.py	LOGGING: django.request WARNING, storage/issues INFO, уровень через DJANGO_LOG_LEVEL

Пункт	Файл/зона	Суть
7.7	tests	4 устаревших теста актуализированы; +17 новых (test_sprint7): guard, зона-гвардия сильнее флага, PIL, LOGGING, разметка

Таблица 4 — Состав Спринта 7

8. Спринт 8: светлый хедер, фильтры, вьювер

Коммиты 59f2820 (дизайн-ядро), 50df590 (производительность) и 7b97e65 (доводка вьювера). Все изменения через токены: version 20261108.1, генерация tokens.css/design-tokens.js/design_colors.py проверена чекером.

Пункт	Файл/зона	Суть
8.1	tokens.json + topbar CSS	Светлый хедер: белая поверхность, акцентная марка, контрасты 4.5:1+; theme-color #FFFFFF
8.2	_documents_panel.html + app.js	Фильтр-бар: 5 селектов + поиск, авто-применение, чипы «Отфильтровано» с × и счётчиком, «Сбросить всё»
8.3	app.js + app.css	Колоночные воронки удалены вместе с мёртвым CSS (~150 строк)
8.4	pdf_viewer.js + viewer.css	Полоса листов: ленивые миниатюры, активный лист, клик-переход; тумблер в тулбаре
8.5	pdf_viewer.js + document_detail.html	Наложение: прозрачность, 3 режима смешивания, drag-совмещение и стрелки; меню «Сравнить» с выбором версии — из любой версии
8.6	services.py + views.py	N+1 реестра: 345 → 32 запроса; perf-скрипты в scripts/
8.7	tests	+12 тестов (test_sprint8): чипы, токены, разметка вьювера, карта pdf_urls

Таблица 5 — Состав Спринта 8

Ключевой принцип обеих спринтов: серверная логика не ослаблялась ни на шаг. Зона-гвардия PUBLISHED/SHARED/ARCHIVE сильнее клиентского флага — это покрыто тестом «админ с флагом всё равно получает 403 для опубликованного документа». Фильтры переиспользуют тот же DocumentFilter и сохранённые виды, чипы строятся на сервере из тех же данных, что применяются к queryset.

9. Скриншоты нового состояния

Скриншоты сняты на сборке после Спринтов 7–8 (демо-проект DEMO-2026, 300 документов, Playwright 1440×900). Полный комплект — в пакете sod_audit5/скриншоты/.

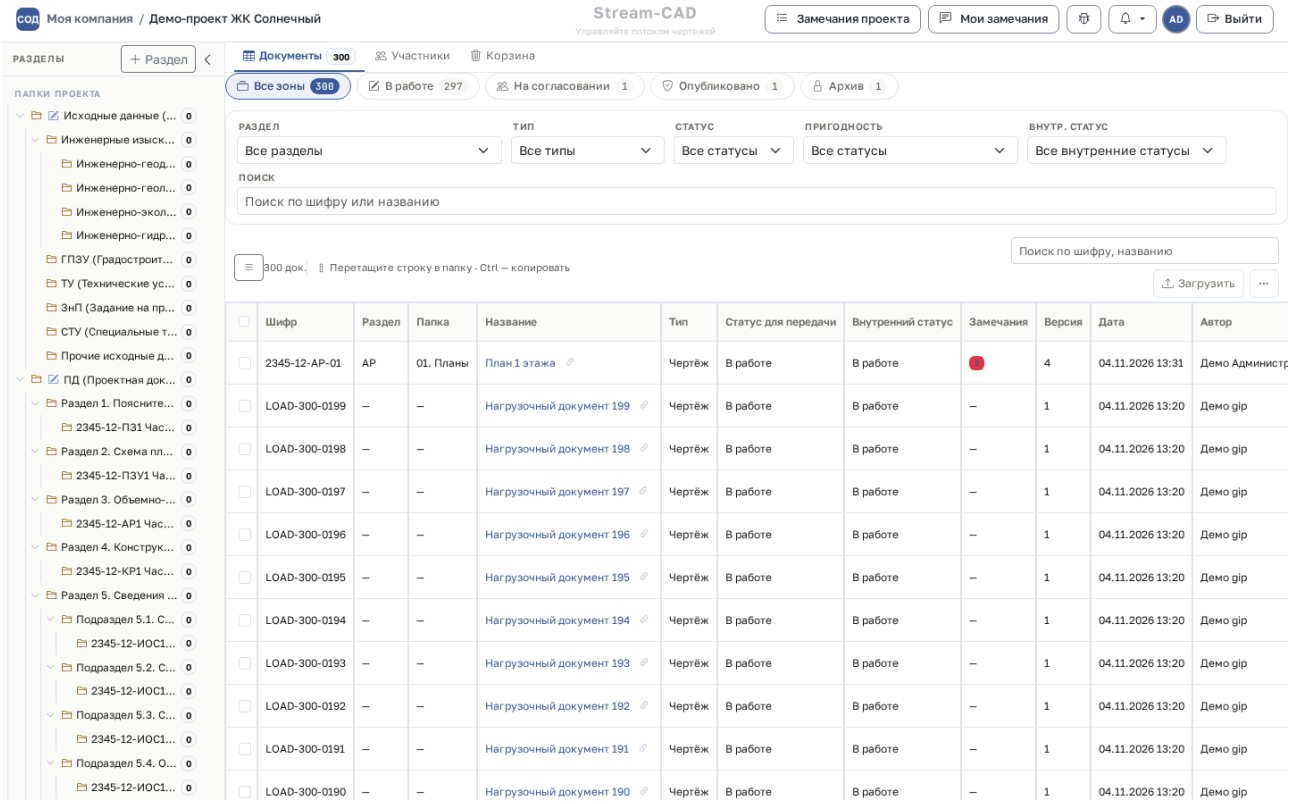


Рис. 2 — Светлый хедер, акцентная марка, видимый фильтр-бар с подписями

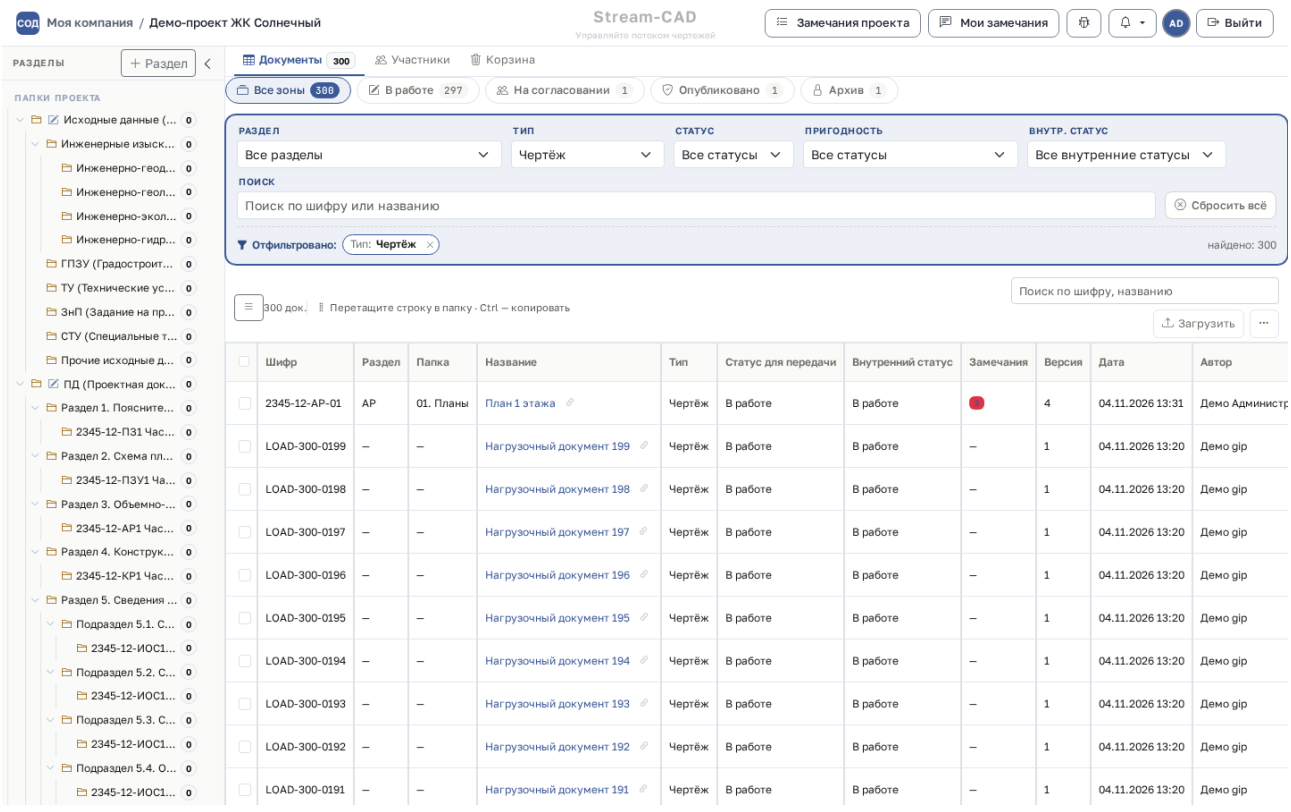


Рис. 3 — Активная фильтрация: акцентная рамка панели, чипы «Отфильтровано» с крестиками и счётчиком найденного, «Сбросить всё»

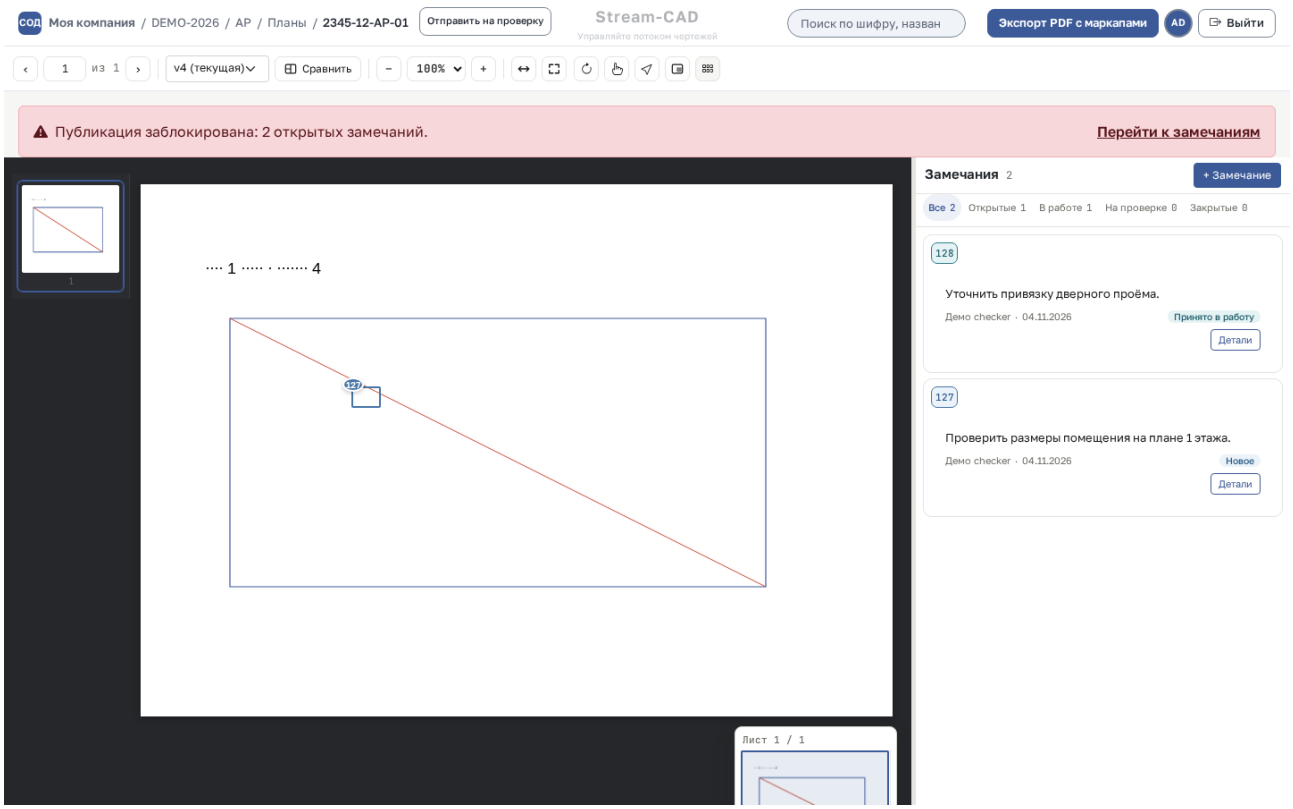


Рис. 4 — Полоса листов во вьювере: активная миниатюра, маркапы замечаний

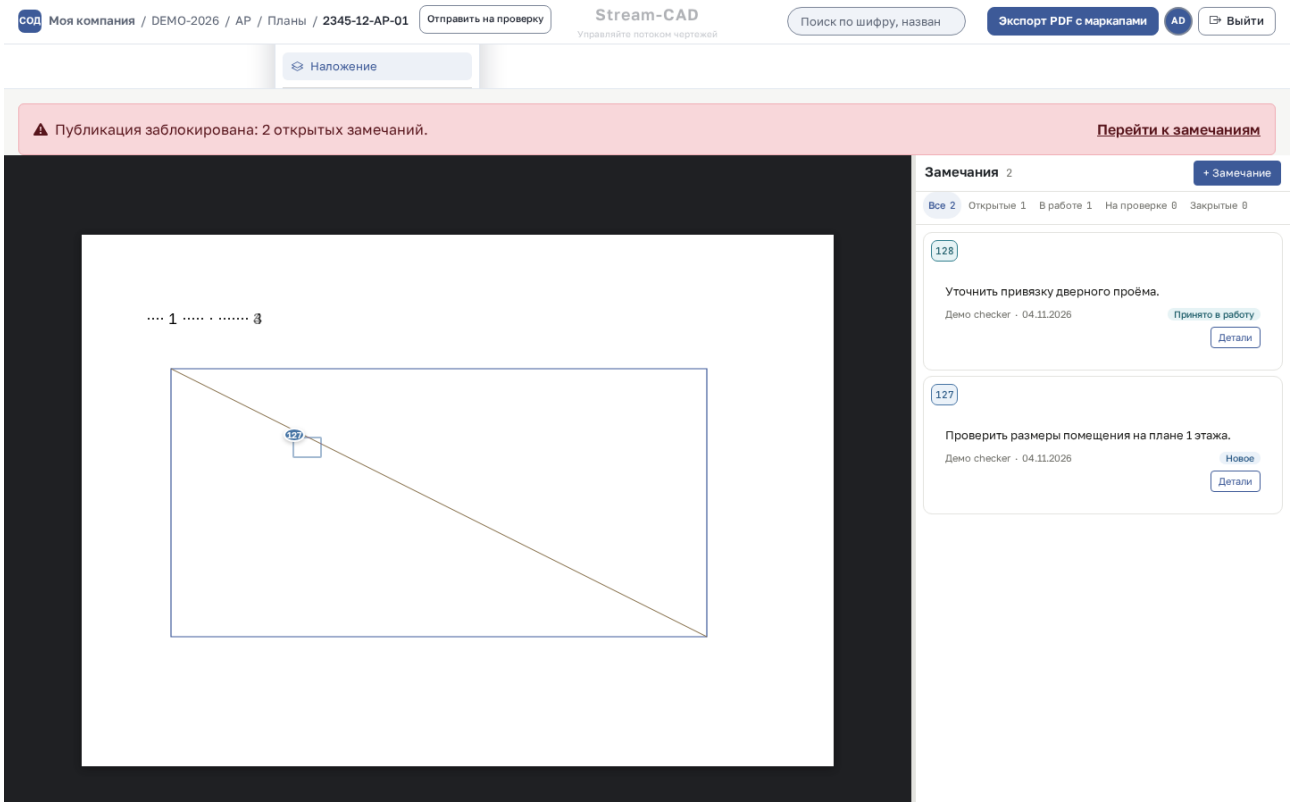


Рис. 5 — Наложение чертежей: ревизии 3 и 4 совмещены, меню «Наложение» активно

10. Бэклог и рекомендации

Приоритезация для беты и прода. Первые два пункта — обязательные перед выходом на VPS.

Приоритет	Задача	Комментарий
P0	SHARE_LINK_TTL из env (30 дней по умолчанию), UI срока жизни ссылки	B-2; год жизни утечки — недопустимо для ИРД
P0	Нагрузочный прогон на PostgreSQL + gunicorn	Замеры главы 5 сделаны на SQLite
P1	FSM для internal_status	Из rework нельзя перескочить в ready_to_share без проверки
P1	Троттлинг submit_feedback + уведомление автору о смене статуса	B-6; закрывает и UX ожидания
P1	Досборка мобильной раскладки: фильтр-бар на 2 колонки, кебабы в таблице	База 4162ff1 уже есть
P2	Остаточные 28 запросов реестра (дерево, служебные списки)	Префетч в get_folder_tree; приоритет ниже — запас есть
P2	Очистка admin_comment в feedback	B-5; мелочь, но раздражает админов
P2	E2E-тесты DnD (Playwright): свой раздел без confirm, чужой с confirm	Контракт 7.1–7.2 дорос до e2e
P3	Dark-тема вьюера из токенов viewer.*	Хедер стал светлым — вьювер остаётся тёмным; это ок, но токены уже позволяют

Таблица 6 — Бэклог после Аудита 5.0

Отдельное слово о процессе. Два цикла подряд аудиты начинаются с красного тестового набора — это систематический риск, который дешевле устранить pre-push hook (pytest/django test на CI), чем очередным аудитом. Архитектура токенов, сервисный слой и FSM — образцовые; когда команда начнёт придерживать пуш до зелёного набора, External-аудиты станут точечными.